

the wire. Some websites store login session and authentication information in the cookie—which, if hijacked, can let attackers use the server without being challenged for user ID and password authentication. This could lead to someone's email account being hijacked, or even their online profile being impersonated, thus resulting in possible monetary losses.

Man in the browser: This is an Internet browser attack wherein a Trojan virus or a malicious script runs in a browser instance to gain control of the Web session. To do this, attackers could exploit inherent un-patched browser vulnerabilities, or vulnerabilities introduced due to the mis-configuration or non-hardening of the OS on which the browser is running. Since the attack takes place in the same security context as the user of the browser, security mechanisms such as SSL and multi-factor authentication prove to be useless. Multiple OS' running a variety of browsers exhibit different vulnerabilities, which could be easily exploited by a program written in JavaScript or similar scripting language.

To explain the real danger caused by this attack, let's consider a user trying to purchase goods on the Internet when the browser is already compromised. The user sees what is on the screen and submits the request, but what the Web server sees is what is actually submitted to it, which can be quite different. If the user submitted his own address for the goods to be shipped to, the address being submitted can be a fictitious one, set up by the attacker to collect the goods—while the user who paid for them will not have a clue about it.

SSL MITM: As we know, the SSL protocol works on public key cryptography concepts, whereby a server is hosted with a digital certificate for online data encryption. This certificate is provided by some trusted authority such as VeriSign, to endorse the identity of the website URL. In a normal situation, when a client (a browser) tries to connect to the secure server, the server provides its certificate to the browser. The browser then checks it against its own list of valid and trusted certificates, and verifies the information contained in it. Once the certificate is accepted, the server and browser both negotiate on a common level of encryption to be used. They then create a key, and transfer data in the encryption form agreed to. If the certificate has expired or is not trusted, the browser flashes a warning to alert those who are using it. In order to compromise this situation, attackers sniff the traffic between browser and Web server, and insert their computer in the network by using standard spoofing techniques. From this point onwards, the attacker's computer runs a proxy tool for the SSL communication. This is done in such a way that the Web server negotiates the SSL key with the attacker's machine, while the communication with the browser is pure text. This results in exposing all the sensitive information to the attackers' computer, which is duly sniffed, recorded and stored for malicious usage. In another case, if the attackers gain physical access to the victim computer temporarily, they install a bogus certificate on it, and then use standard IP spoofing to divert traffic, establish an SSL connection with the Web server using the trusted certificate, and also with the browser, by using the bogus certificate. This

is done to ensure that the URL is seen as HTTPS, and the actual communication is indeed SSL—helping the attackers to hide, but data is being stolen in the process.

Wireless MITM: Similar to wired attacks, in the case of wireless networks, the data stealing can actually be a bit easier. It exploits design vulnerabilities in Wi-Fi networks, whereby a dummy access point is set up on the network, with the same SSID signature, and a stronger signal. The next step is to disrupt client traffic to the real legitimate wireless router, either by spoofing or by subjecting the router to a DoS attack using a packet storm. Once the router gives up, a Wi-Fi connection is established by the dummy router, which starts the packet sniffing and data theft. There are a few other ideas, such as logging into the real router by using a brute-force method, and creating a wireless bridging with the dummy router; or faking the MAC address of the real router to fool and lure Wi-Fi clients to the dummy router, etc. Due to the use of wireless signals, it is unfortunately possible for the attacker to steal data undetected, almost forever. Due to a lack of knowledge, it is very common to have wireless routers at home or work, which are not configured correctly, or not secured using appropriate keys or passwords.

Other MITM attacks: It is important to note that MITM attacks are possible in the critical networking components, as well as with new technologies. Routers and managed switches can be spoofed resulting in a higher security impact, and the firewalls can also be fooled to deliver legitimate traffic to a rogue machine. Technologies such as mobile computing and Bluetooth are vulnerable to MITM attacks, but those are out of the scope of this article.

Protecting FOSS systems

While the MITM attack is a difficult one to tackle, there are a few preventive mechanisms that all network administrators should adopt in their infrastructure. Since the heart of an MITM attack is packet sniffing and spoofing, utmost care needs to be taken while designing the network to introduce network monitoring points. Using intrusion prevention systems proves to be a very good choice for large companies, where the network is complex, and hence more susceptible to MITM. Since this attack exploits the inherent vulnerabilities of the unprotected TCP/IP protocol, techniques such as IPSec security can be used to ensure traffic authentication at lower OSI layers.

For a data centre hosting FOSS systems, the very first thing to implement is MAC address security. This can be achieved by choosing a host-based model, or configuring the managed switches and DHCP systems appropriately. To protect DNS systems, one can use DNSSEC, which digitally signs each DNS query request and its response, thus endorsing its legitimacy. In case of very critical IT infrastructures, using manual 'hosts' entries instead of DNS servers can actually help fix DNS hijacking problems. For FOSS-based Web infrastructures, it is recommended that you use stronger ciphers implemented around TLS technology instead of SSL. Also,